

Day 15 – Detection Basics

Detection Basics

A **security detection** is a rule, analytic, or behavioral pattern that identifies suspicious or malicious activity from security telemetry. Unlike preventive controls, detections identify attacks that are in progress or have already occurred, enabling SOC analysts to investigate and respond.

Detection vs Alert

- **Detection:** Logic or rule that identifies suspicious behavior.
- **Alert:** Notification generated when a detection rule is triggered.

Common Detection Data Sources

- **Windows Security Logs:** Authentication, privilege, and process events.
 - **Sysmon:** Process creation, network connections, registry changes, DNS queries.
 - **Cloud Logs:** AWS CloudTrail, Azure Activity Logs, Microsoft Defender XDR.
 - **Network Logs:** Firewall, IDS/IPS, Proxy, and DNS logs.
-

Detection Types

Detection Type	Primary Purpose
Signature-Based	Detects known malware or attack patterns.
Rule-Based	Uses predefined conditions (e.g., failed login threshold).
Behavioral	Detects deviations from normal user or system behavior.
Threat Intelligence	Matches activity against known malicious IOCs.
AI/ML	Identifies anomalies and previously unseen attack patterns.

Detection Tuning

Detection tuning improves alert quality by reducing **false positives** while maintaining visibility into genuine threats.

Effective tuning techniques:

- Focus on suspicious command-line arguments (e.g., -EncodedCommand, -ExecutionPolicy Bypass).
- Monitor unusual parent-child process relationships.
- Allowlist trusted accounts and script paths.
- Correlate PowerShell activity with authentication, registry, DNS, and network events.
- Apply severity based on behavioral context instead of single events.

Practical Exercise Findings

- Created detection logic for brute-force attacks, encoded PowerShell, and suspicious DNS activity using event thresholds and behavioral indicators.
 - Compared signature, rule-based, behavioral, threat intelligence, and AI/ML detections, understanding their strengths, limitations, and SOC use cases.
 - Tuned an overly broad PowerShell detection by adding command-line analysis, trusted allowlists, parent-process checks, event correlation, and severity-based alerting to reduce false positives.
 - Designed five SOC detections for brute-force login, encoded PowerShell, registry persistence, suspicious DNS activity, and outbound HTTPS communication, including detection logic, data sources, MITRE ATT&CK mapping, severity, and tuning recommendations.
-

MITRE ATT&CK

- **T1110** – Brute Force
- **T1059.001** – PowerShell
- **T1027** – Obfuscated Files or Information
- **T1547.001** – Registry Run Keys / Startup Folder
- **T1071.004** – DNS
- **T1071.001** – Application Layer Protocol (Web Protocols)